

Figure 1: A typical DDoS attack

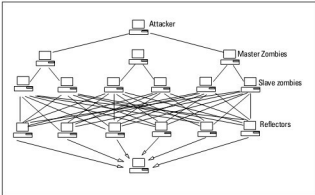


Figure 2: A typical DRDoS attack

```
: {1000 times}
</html>
```

Such a page, when loaded, will send the same request 1000 times every 2 seconds, and will consume a lot of the Web server's bandwidth. Thus, the target server will not be able to respond to other clients, and eventually, legitimate clients will be denied services from the server.

Now let us assume that an attacker would like to launch a DoS attack on *example.com* by bombarding it with numerous messages. Also assume that *example.com* has abundant resources and considerable bandwidth (which is most often the case). It is then difficult for the attackers to generate a sufficient number of messages from a single machine (as in the above scenario) to overload those resources. However, imagine the consequences if they got 100,000 machines under their control, in order to simultaneously generate requests to *example.com*. Each of the attacking machines (compromised machines that have been infected by malicious code) may be only moderately provisioned (have a slow processor and be on a mere modem link), but together, they form a formidable attack network—which, with proper use, could overwhelm even a well-provisioned victim site. This is a distributed denial-of-service (DDoS) attack, and the machines under the attacker's control are termed as zombies/agents.

Distributed denial-of-service (DDoS) attacks

In a typical DDoS attack, the attacker's 'army' consists of *master zombies* and *slave zombies*. The attacker coordinates and orders master zombies and they, in turn, coordinate and trigger slave zombies. More specifically, the attacker sends an attack command to the master zombies, and activates all attack processes on those machines, which are in hibernation, waiting for the appropriate command to wake up and start attacking. Then the master zombies duplicate the attack commands to each of their slave zombies, ordering them to mount a DDoS attack against the victim.

In this way, the zombie systems begin to send a large volume of packets to the victim, flooding it with useless loads, and exhausting its resources. Figure 1 shows this kind of DDoS attack.

In DDoS attacks, spoofed source IP addresses are used in the packets of the attack traffic. Attackers prefer to use such counterfeit source IP addresses for two major reasons: first, to hide the identity of the zombies, so that the victim cannot trace the attack back to them. The second reason is to discourage any attempt by the victim to filter out the malicious traffic.

Types of DoS attacks

Though there are numerous flavours of DoS attacks, here we'll discuss only those which affect the Web server and Web applications.

TCP SYN flooding attacks

DoS attacks often exploit stateful network protocols, because these protocols consume resources to maintain state. TCP SYN flooding is one such attack, and had a wide impact on many systems. When a client attempts to establish a TCP connection to a server, the client first sends a SYN message to the server. The server acknowledges this by sending a SYN-ACK message to the client. The client completes establishing of the connection by responding with an ACK message. The connection between the client and the server is then open, and service-specific data can be exchanged between them.

The abuse occurs at the 'half-open' state when the server is waiting for the client's ACK message, after sending the SYN-ACK message to the client. The server needs to allocate memory to store information about the half-open connection, and this memory will not be released until the server either receives the final ACK message, or the half-open connection expires (times out).

Attackers can easily create half-open connections by spoofing source IPs in SYN messages, or ignoring SYN-ACKs. The consequence is that the final ACK message will never be sent to the victim. Because the victim normally only allocates a limited amount of space in its process table, too many half-open connections will soon fill the space. Even though the half-open connections will eventually expire due to their time-out, zombies can aggressively send spoofed TCP SYN packets, requesting connections at a much higher rate than the expiration rate. Finally, the victim will be unable to accept any new incoming connections, and thus cannot provide services.